

STARTER TEMPLATE · ADAPT BEFORE ADOPTION

# AI Workflow SOP Template

A standard operating procedure that documents a single AI-assisted workflow with enough model-risk discipline that an examiner can read it and know exactly what the AI does, who checks it, and when it gets shut off.

## WHO IT IS FOR

Operations, compliance, lending, any team running AI-assisted work

## FILL TIME

14 min

## WHAT'S INSIDE

- 01 Workflow identity & inventory entry
- 02 Scope, boundaries & prohibited uses
- 03 Inputs, data sources & data handling
- 04 Process steps & human-in-the-loop control
- 05 Vendor / third-party management (if applicable)
- 06 Validation, monitoring & performance metrics
- 07 Risk tiering & governance approval
- 08 Incident response, recovery & retirement
- 09 What good looks like / common mistakes

## SECTION 01

## Workflow identity & inventory entry

Before describing how the AI works, pin down what this workflow is and register it. The AIEOG Lexicon defines an AI use-case inventory as a maintained record of where and how AI is used and the outputs it produces; this SOP is one row in that inventory. An examiner's first question is "show me your inventory."

- <sup>a</sup> Workflow name & ID — Recommended: give every AI workflow a stable ID and a plain-English name a director understands. Example: "AI-LEND-001 — AI-assisted commercial loan-memo drafting."
- <sup>a</sup> Business purpose & output — Recommended: one sentence on the job plus the concrete artifact. Example: "Generate a first-draft credit memo (narrative sections only) from approved underwriting inputs; output is a Word draft an analyst edits and a credit officer approves."
- <sup>a</sup> Owner & accountable executive — Recommended: name one accountable owner (a person, not a committee) and the senior executive who owns the risk. Example: "Owner: VP Commercial Credit; accountable executive: Chief Credit Officer."
- <sup>a</sup> AI/model type — Recommended: state plainly whether this is generative AI, a vendor feature, or an internal model; this drives which controls apply. Example: "Third-party generative AI accessed via the LOS vendor's add-on; vendor-hosted."
- <sup>a</sup> Inventory status & tier — Recommended: record date added and risk tier. Example: "Added 2026-03-01; Tier: Moderate — assists a credit decision but produces no automated decision or score."

## SECTION 02

## Scope, boundaries & prohibited uses

The single most useful thing this SOP does is draw a hard line around what the AI may and may not do — that line prevents scope creep and is what an examiner tests.

- <sup>a</sup> In scope — Recommended: list the specific tasks, narrowly. Example: "Drafting the narrative/qualitative sections of the memo from analyst-supplied facts and approved templates."
- <sup>a</sup> Out of scope / prohibited — Adopt verbatim: "This tool does not make or recommend credit decisions, does not assign or influence risk ratings, does not calculate ratios or covenants, does not communicate with the borrower, and is not a system of record. Numbers, ratings, and conclusions are produced by staff, not the AI."
- <sup>a</sup> Population & volume — Recommended: state who/what flows through and rough volume. Example: "All C&I and CRE requests over \$250k; ~30 memos/month."
- <sup>a</sup> Fair-lending boundary — Recommended: state explicitly whether it touches protected-class-sensitive decisions, even if the answer is no. Example: "Commercial credit only; no consumer/ECOA-covered lending; no protected-class or proxy variables provided; adverse-action language drafted by staff, not the AI."

## SECTION 03

## Inputs, data sources & data handling

SR 11-7 treats data quality as part of model soundness. Name every source, classify the data, and state what may leave the building.

- <sup>a</sup> Data sources — Recommended: name each system and the exact data, not categories. Example: "Borrower financials/tax returns (analyst-uploaded), spreading output from [core], prior memos from [LOS], analyst-selected public industry data."
- <sup>a</sup> Data classification & NPI handling — Adopt verbatim: "Inputs include Confidential and Nonpublic Personal Information. No customer NPI is used to train, fine-tune, or improve any vendor or public model; inputs and outputs are not retained outside the bank's contracted, access-controlled environment."
- <sup>a</sup> Prohibited inputs — Recommended: name what must never be entered. Example: "Do not paste full SSNs, account numbers, or consumer credit-report data; redact before upload."
- <sup>a</sup> Input validation — Recommended: require a human to confirm inputs are complete and from approved sources before running. Example: "Analyst confirms the spreading is final and statements are the signed versions before generating."

## SECTION 04

## Process steps & human-in-the-loop control

This is the heart of the SOP. The AIEOG Lexicon defines human-in-the-loop as a human integrated into the system's decision-making; SR 11-7 stresses models inform but do not replace informed human judgment. Write the steps so the human checkpoint is a required, evidenced action.

- <sup>a</sup> Authority to override — Recommended: state staff may discard the AI draft and write manually at any time, no justification required.
1. Prepare & validate inputs — the analyst assembles approved inputs and confirms completeness.
  2. Generate draft — run the AI using the approved prompt/template only; ad-hoc prompting outside the template is out of scope.
  3. Human review & correction (the HITL control) — Adopt verbatim: "A qualified analyst reviews every AI-generated section line by line for factual accuracy, hallucinated figures or citations, completeness, and tone before it is used; the analyst is responsible for the content as if they had written it."
  4. Independent approval — a second, more senior role signs off before the memo advances (the "effective challenge" SR 11-7 expects); approval is logged.
  5. Record & retain — retain the final human-approved artifact (and, where feasible, the AI draft) per the retention schedule.

## SECTION 05

## Vendor / third-party management (if applicable)

If the AI is bought, not built, the 2023 Interagency TPRM guidance governs it across the life cycle — planning, due diligence/selection, contract, ongoing monitoring, termination — scaled to risk and criticality. Skip only if fully internal.

- <sup>a</sup> Vendor & criticality — Recommended: name the vendor, hosting model, and whether the relationship is "critical." Example: "LOS provider AI add-on; SaaS; not critical — workflow can run manually if unavailable."
- <sup>a</sup> Due-diligence evidence on file — Recommended: list the artifacts you actually hold (SOC 2, model/data-use documentation, security review, financial condition).
- <sup>a</sup> Key contract terms — Adopt verbatim: "The contract prohibits use of bank or customer data to train or improve the vendor's models, grants the bank and its regulators audit and examination access, and defines data return/deletion at termination."
- <sup>a</sup> Ongoing monitoring & continuity — Recommended: state cadence, re-review triggers, and the fallback if the vendor fails. Example: "Annual review; re-review on any model-version change; fallback = manual drafting."

## SECTION 06

## Validation, monitoring & performance metrics

SR 11-7 validation rests on conceptual soundness, ongoing monitoring, and outcomes analysis; NIST's Measure function is how you know controls work and catch drift. For a moderate-tier HITL workflow, validation can be proportionate — but it must exist and be evidenced.

- <sup>a</sup> Pre-deployment check — Recommended: document the initial test that established fitness. Example: "Before go-live, 20 historical deals were drafted with the tool and compared to the original memos; coverage and accuracy signed off by the CCO."
- <sup>a</sup> Ongoing metrics — Recommended: pick 2-4 metrics with owners and frequency. Example: "Monthly: hallucination/error rate found in review; % of drafts needing material rework; any factual error that reached committee (target zero)."
- <sup>a</sup> Threshold & escalation — Adopt verbatim: "If the material-error rate exceeds the established threshold for two consecutive months, the workflow owner escalates to the accountable executive and use of the tool is paused pending review."
- <sup>a</sup> Independent review & cadence — Recommended: name who reviews independently of the owner and how often; full SOP review annually plus event triggers (vendor version change, material error, scope change).

## SECTION 07

## Risk tiering & governance approval

NIST's Govern function is the cross-cutting layer — who approves the use case and how oversight is resourced. Tiering sets how much control intensity the workflow earns; proportionality is the point of the risk-based approach.

- <sup>a</sup> Risk tier & rationale — Recommended: a simple Low/Moderate/High keyed to decision impact and autonomy. Example: "Moderate — influences a memo that feeds a human decision; no automated decision, score, or customer-facing output. (High if it scored or auto-decisioned credit.)"
- <sup>a</sup> Control intensity by tier — Recommended: state what each tier requires so the rating has teeth (e.g., Moderate = named owner, HITL on every output, annual independent review, monitoring; High adds formal independent validation pre-deployment and board reporting).
- <sup>a</sup> Approvals on record & policy linkage — Recommended: list approvals/dates and cite the governing internal policies (AI Use Policy, Model Risk Policy, Third-Party Risk Policy).
- <sup>a</sup> Change management — Adopt verbatim: "Material changes to inputs, scope, the underlying model/version, or the vendor require re-approval through this governance process before continued use; changes are version-logged on this SOP."

## SECTION 08

## Incident response, recovery & retirement

NIST's Manage function covers response, incident handling, and recovery. Decide in advance what happens when the AI gets it wrong and how the workflow is wound down.

- <sup>a</sup> Failure modes — Recommended: name the realistic ways it goes wrong (hallucinated figures, fabricated citations, outdated data, outage, data exposure).
- <sup>a</sup> Incident response — Recommended: define who to notify and the immediate containment. Example: "On a material error reaching committee or any data-exposure event, the owner notifies the accountable executive and the CISO/incident function the same business day; tool use paused if exposure is suspected."
- <sup>a</sup> Recovery / fallback — Recommended: confirm the manual path keeps the business running; reprocess affected items through full human review.
- <sup>a</sup> Retirement — Recommended: state how it is decommissioned — disable vendor access, confirm data deletion/return per contract, archive the SOP, mark the use case "Retired" with date and reason.

## SECTION 09

## What good looks like / common mistakes

A quick self-check before handing this to an examiner. The difference between a credible SOP and a checkbox is whether the controls are actually happening and evidenced.

- a What good looks like — a reader who has never seen the tool can state in a minute what it does, what it's forbidden to do, who checks every output, and what shuts it off; every control claim is backed by a producible record.
- a Common mistake — listing capabilities but not prohibitions; the out-of-scope language is what limits risk, so write it first.
- a Common mistake — "we monitor performance" with no threshold or owner; set a number that triggers a pause and name who watches it.
- a Common mistake — vague data handling that leaves open whether NPI trains a public model; state the no-training and retention rules and tie them to the contract.
- a Common mistake — letting the SOP go stale; an un-updated SOP after a vendor model upgrade is itself a finding. Date it, version it, re-review on the triggers above.

### SOURCE BASIS

- SR 11-7 — Supervisory Guidance on Model Risk Management (Federal Reserve / OCC); note the 2026 SR 26-2 risk-based modernization the institution may be transitioning to
- NIST AI Risk Management Framework (AI RMF 1.0): Govern, Map, Measure, Manage
- Interagency Guidance on Third-Party Relationships: Risk Management (FRB / FDIC / OCC, June 2023)
- AIEOG AI Lexicon — AI use case inventory, human-in-the-loop (US Treasury / FBIIC / FSSCC, Feb 2026)

### ADAPT BEFORE ADOPTION

This is a starter template, not legal advice or an examiner-approved policy. Replace every [bracketed] placeholder, align the language with your institution's policies, and route the final document through compliance, risk, and legal review.